RFC v0.4 — Modelagem de Risco Antifraude Pix (1)

Status: Draft v0.4 · 17/10/2026. Especificação consolidada, com tabelas, exemplos, diagrama, política única e cenários de teste v0.4. As definições anteriores conflitantes foram substituídas.

Origem: desafio QI Tech Antifraude Pix. Cenários, sinais, pesos e políticas abaixo são proposta de modelagem da equipe, não exigências regulatórias nem resultados validados com dados reais. Números do Banco Central aparecem como referência citada, não como obrigação do desafio.

1. Problema, objetivo e limites do escopo

Evaluate two independent dimensions at authorization time: payer risk (account access, behavior, spending) and recipient risk (account, holder, receiving network). Return only `approved`, `two_factor_required` or `rejected`, with auditable metadata. Payer 2FA can help with account takeover but is not a complete mitigation for socially engineered authorized transfers.

Out of core scope: actual bank device enrollment, 2FA completion callback, settlement/ledger, real DICT or reputation services, trained ML, nationwide Pix visibility and true financial or regulatory limit enforcement. An `approved` result is an engine recommendation only, not proof of settlement, authentication or legitimacy.

2. Contrato da API e identidades

Preservar os endpoints do desafio: `POST /pix/transaction` e `GET /pix/transaction/{id}`. Não adicionar campos obrigatórios ao pedido nem criar rota pública de cadastro de device. O valor é expresso em **centavos**, e datas recebidas possuem fuso.

Exemplo de entrada

```
{
  "id": "pix-000123",
  "amount": 150000,
  "transaction_date": "2026-10-17T22:15:00-03:00",
  "source_account": {
    "branch": "0001", "account_number": "88213",
    "opening_date": "2025-03-02T10:00:00-03:00",
    "owner": {"document_number": "123.456.789-09"}
  },
  "destination_account": {
    "participant": "60701190", "branch": "3675", "account_number": "10442",
    "opening_date": "2026-10-10T09:00:00-03:00",
    "owner": {"document_number": "987.654.321-00"}
  },
  "source": {
    "device_id": "dvc-9f2c71a8", "channel": "app", "ip": "198.51.100.23",
    "geolocation": {"latitude": -23.56, "longitude": -46.65}
  }
}
```

Exemplo ilustrativo de resposta

Exemplo ilustrativo: P03 e P06 somam 36 pontos; L01 (+8) e L02 (+10) somam 18 pontos brutos, limitados a 15 pela família Limite. Resultado do pagador: 51 pontos. O exemplo exibe os sinais acionados; no uso real registrar também os não acionados e indisponíveis.


```
{
  "key": "8f0c2b1e-5d7a-4c1e-9b3a-2f6d7e8a9c10",
  "status": "two_factor_required",
  "metadata": {
    "policy_version": "v0.4",
    "decision_rule": "D-ATO-1",
    "device": {
      "registration_status": "unregistered",
      "registration_source": "demo_seed",
      "previously_observed": true
    },
    "scores": {"payer": 51, "recipient": 0},
    "evidence_sufficiency": {"payer": "medium", "recipient": "unavailable"},
    "reasons": ["Dispositivo sem cadastro simulado ativo e valor acima do perfi
l"],
    "signals": [
      {"code": "P03", "status": "triggered", "points": 18,
       "evidence": {"registration_status": "unregistered"}},
      {"code": "P06", "status": "triggered", "points": 18,
       "evidence": {"amount": 150000, "historical_median": 20000, "ratio": 7.
5}},
      {"code": "L02", "status": "triggered", "points": 10,
       "evidence": {"amount": 150000, "unregistered_device": true}},
      {"code": "L01", "status": "triggered", "points": 8,
       "evidence": {"local_hour": "22:15", "amount": 150000}}
    ],
    "family_contributions": {
      "payer_behavior": {"raw": 36, "applied": 36, "cap": 45},
      "limit": {"raw": 18, "applied": 15, "cap": 15}
    }
  }
}
```


No caso real, incluir todos os sinais avaliados, até `not_triggered` e `unavailable`; o score deve corresponder exatamente às contribuições após teto. Não inferir conclusão de 2FA, liquidação ou fraude confirmada.

Normalização e integridade

- **Titular pagador e titular destinatário:** documentos normalizados independentemente. CPF contém 11 dígitos. CNPJ deve preservar letras válidas e zeros iniciais quando o schema suportar CNPJ alfanumérico; se o Base Service do desafio exigir números apenas, declarar a limitação e testá-la. Nunca remover letras silenciosamente.
- **Conta destinatária:** chave composta `participant (ISPB) + branch + account_number`; não equiparar histórico desta conta ao de todas as contas do mesmo titular.
- **Idempotência:** `UNIQUE(external_id)`; primeiro POST válido 201; repetição com payload canônico igual 200 e análise idêntica; mesmo ID com dados diferentes 409. Em corrida entre duplicatas, tratar conflito de unicidade por leitura/comparação, não 500.

- **Tempo:** registrar `received_at` e `evaluated_at` do servidor em UTC separadamente da data declarada e verificar skew/tolerância explícita. L01 usa hora local `America/Sao_Paulo`; contagens móveis usam tempo controlado pelo servidor.
- **Segurança:** manter `INTERNAL-TOKEN` e padrão de erros do Base Service. Logs com `request_id`, sem documento integral ou payload sensível sem necessidade.

HTTP	Caso	Tratamento
400	Payload fora do schema / restrição temporal definida	Erro contratual, não veredito antifraude
403	INTERNAL-TOKEN ausente ou inválido	Erro do Base Service
404	GET de ID inexistente	PixTransactionNotFound
409	Mesmo ID com payload canônico divergente	PixTransactionIdConflict
500	Falha inesperada de avaliação	Sem veredito; recibo durável marcado failed

3. Modelo de informação: observação não é confiança

As fontes são distintas: recibos e observações concluídas, cadastro bancário simulado, baseline comportamental e adaptadores internos de restrição e inteligência. Apenas recibos `completed` alimentam velocity, conforme §8.

1. **Observações:** cada ID avaliado e concluído uma vez, inclusive decisões rejected e two_factor_required; contribuem para velocity/rede/montante tentado. Recibos processing/failed são auditados, mas não entram nos agregados; tentativa não cadastra device nem prova relação segura.
2. **Simulated bank device registry:** a separate *seed-only* internal dataset describing registration for a `payer_document + device_id` pair. A successful registration lookup is evidence only of simulated registration, not legitimacy of the present transaction.
3. **Behavioral baseline proxies:** previous engine-approved observations (not rejected/challenged), with explicit `engine_approved_proxy` provenance. Even approval is not confirmation of authentication, settlement or lack of fraud. Recent suspect observations do not become their own baseline.

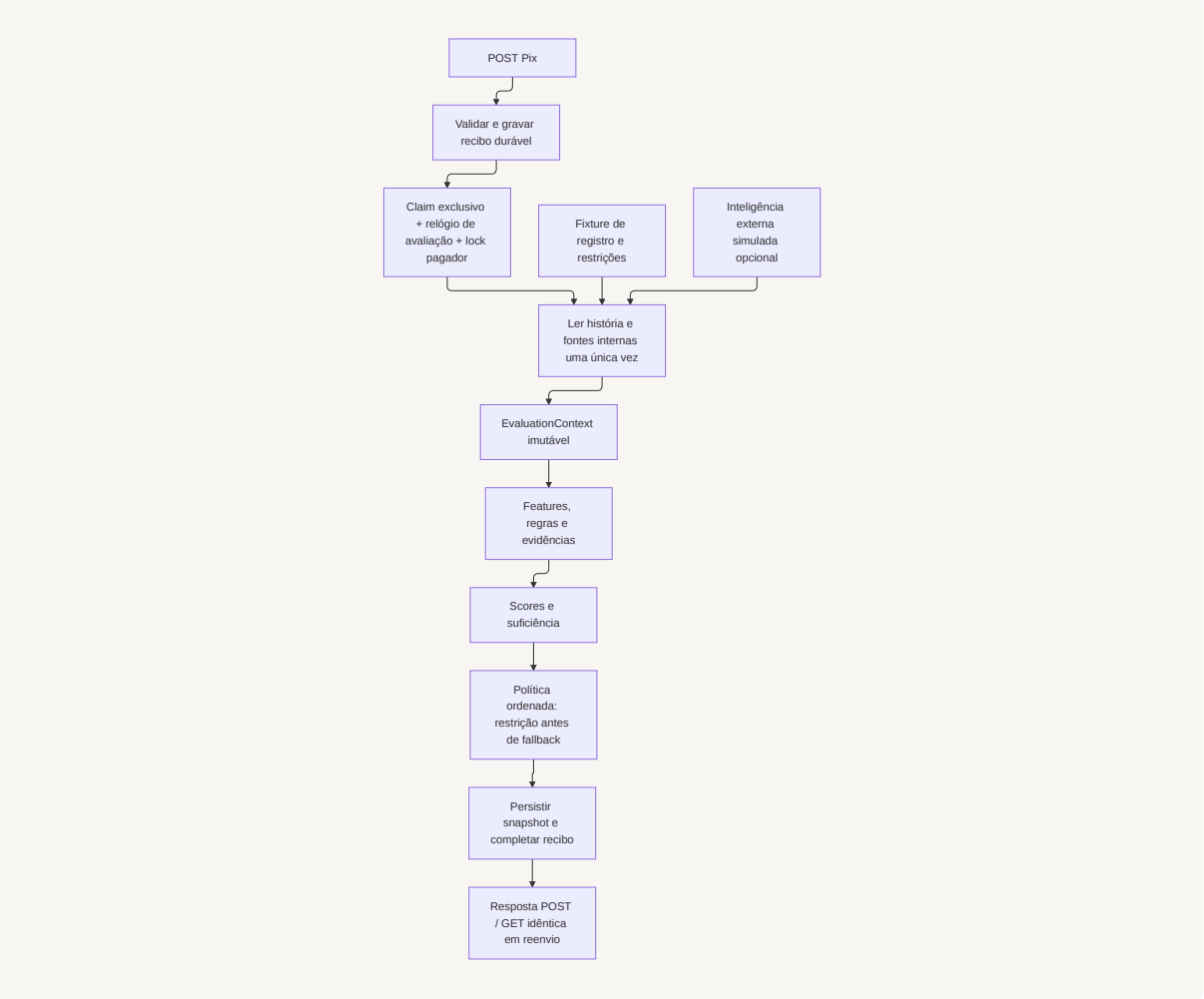
Seeded device registry

Proposed internal table `payer_device_registration`:

- `payer_document` normalized; `device_id`; `registered_at`; `revoked_at` nullable; `provenance` (initially `demo_seed`).
- Registration is per payer-device pair, never device-global. For evaluation instant `t`, active iff `registered_at <= t` and (`revoked_at IS NULL` or `revoked_at > t`).
- Seed registry via a reproducible deployment/test fixture, not via POST Pix. Pix processing cannot insert, renew, revoke or otherwise promote registration.
- `registration_status` is `registered`, `unregistered` (complete fixture lookup with no active registration) or `unavailable` (registry inaccessible/incomplete). `unavailable` is not `unregistered` and not `registered`. In demo, document the assumption that fixtures constitute a complete simulated bank registry for covered payer records; don't silently equate absence in arbitrary partial data with bank non-registration.
- Keep independent `previously_observed` from attempted-history. Never change registration because 2FA was requested or a Pix was approved.
- Example metadata: `device: {registration_status: "unregistered", registration_source: "demo_seed", previously_observed: true}`. No `trusted: true` claim.
- Since the API has no 2FA result callback, challenged attempts are unresolved here. They remain attempted-history and **never** enroll the device or establish reassuring behavioral/relationship history. Persist the original challenged result. No fabricated completion endpoint or automatic trust promotion.

4. Fluxo de avaliação v0.4

1. Validar contrato e payload canônico; gravar recibo durável, com `received_at` de servidor. Garantir reivindicação exclusiva com lease/`owner_token` e recuperar processamento abandonado (seção 8).
2. Capturar `evaluated_at`/clock controlado do servidor uma vez; validar tolerância de `transaction_date`. Obter lock por pagador e consultar história disponível, cadastro bancário simulado, restrições ativas e provider opcional. Distinguir titular e conta exata.
3. Construir **EvaluationContext imutável** contendo clock, identidades, features com cobertura, fonte/versão/disponibilidade, evidências externas já deduplicadas, registro do device e restrições. Excluir a observação atual das baselines; incluí-la virtualmente uma vez nos contadores de tentativas.
4. Rodar regras, agregação com tetos e política **sobre esse contexto**, sem novas leituras a banco/provedor entre regras. Sinal sem pré-condição ou fonte disponível é `unavailable`, não zero seguro.
5. Persistir contexto/evidências suficientes, sinais completos, pontuações reproduzíveis, `decision_rule`, versão e resposta da API; gravar `completed` atomicamente com a análise. GET retorna snapshot original.
6. Se ocorrer falha, manter recibo `failed`/recuperável e erro documentado **sem veredito**; não completar Pix pelo timeout.



Velocidade usa relógio do servidor; L01 usa hora local de `transaction_date` validada. Testes podem injetar relógio controlado apenas no ambiente de teste, sem permitir que clientes configurem o relógio por payload público.

5. Catálogo de sinais v0.4

Sinais determinísticos com resultados `triggered`, `not_triggered` ou `unavailable`. Pesos e limites são hipóteses demonstrativas. Tentar, aprovar e liquidar são eventos diferentes. Velocity utiliza todas as tentativas distintas; confiança comportamental usa apenas aprovações anteriores do motor como proxy limitado.

Código	Sinal	Condição v0.4	Pontos / eixo	Família	Pré-condição e interpretação
P01	Conta pagadora recente	Conta pagadora <7 dias	+10 pagador	Conta pagadora	Data informada; não prova fraude
L01	Valor noturno	20h–05h59 em São Paulo e valor >100000 centavos	+8 pagador	Limite	Heurística; enforcement bancário é externo
P03	Dispositivo não registrado	Par pagador–device sem registro ativo na fixture bancária	+18 pagador	Comportamento	Fonte indisponível → unavailable; observação não registra
L02	Dispositivo não registrado e valor	P03 e (valor >20000 ou soma diária em todos devices não registrados >100000)	+10 pagador	Limite	Não é teto regulatório; indisponibilidade → unavailable
P04	Velocity do pagador	≥5 tentativas distintas em 5 min, atual inclusa	+20 pagador	Velocity	Todos os status, sem reenvio idempotente
P05	Montante em 1h	Tentativas distintas acumuladas >800000, atual inclusa	+15 pagador	Montante	Todas as tentativas
P06	Valor atípico	>5× mediana qualificada e valor ≥100000	+18 pagador	Comportamento	≥10 aprovações anteriores do motor em ≥7 dias; proxy, não liquidação
P07	Múltiplos novos titulares	≥3 titulares sem relação-base aprovada tentados em 10 min	+18 pagador	Comportamento	Tentativas não estabelecem relação
P08	Device compartilhado	Mesmo device em ≥3 pagadores distintos em 24h	+12 pagador	Comportamento	Sinal auxiliar, não prova fraude
P09	IP fora do baseline	IP ausente de histórico-base qualificado do pagador	+6 pagador	Comportamento	Não confundir observed_in_attempts com in_baseline
P10	Dispositivo/IP combinados	P03 e P09 acionados	+12 pagador	Comportamento	Interação sujeita a teto; não basta nunca observado
R01	Conta destino nova	Conta exata <7 dias	+12 destinatário	Rede destinatário	Idade da conta, não do titular
R02	Rajada para titular	≥5 tentativas em 10 min para mesmo titular	+16 destinatário	Rede destinatário	Exibir também contagem da conta exata

Código	Sinal	Condição v0.4	Pontos / eixo	Família	Pré-condição e interpretação
R03	Pagadores diversos	≥4 pagadores distintos/1h para mesmo titular	+20 destinatário	Rede destinatário	Exibir também pagadores na conta exata
R04	Concentração na conta nova	R01 e ≥4 pagadores distintos/1h na mesma conta exata	+15 destinatário	Rede destinatário	Não usar só R03 por titular; não rejeitar automaticamente
REL01	Titular sem relação-base	Sem aprovação prévia do motor no par pagador→titular	+8 destinatário	Relação	Requer histórico-base do pagador
REL02	Relação recorrente	≥3 aprovações anteriores do motor no par em ≥7 dias, sem anomalia recente	−8 destinatário	Relação	Desafios/rejeições não contam; redutor limitado
REL03	Mesmo titular	Documento normalizado nas duas pontas igual	−5 destinatário	Relação	Não força aprovação

Inteligência externa simulada: adaptador interno/fixtures por documento normalizado, respostas `clear`, `suspicious`, `confirmed_in_mock`, `unavailable`, com IDs de ocorrência, timestamp, severidade, versão e proveniência. É fonte de evidência, não de decisão; cada ocorrência pontua uma só vez, sujeita a teto versionado. `clear` não comprova segurança e `confirmed_in_mock` não comprova fraude real.

Contratos exatos das features históricas

Todas as janelas móveis, salvo indicação contrária, são **[t−janela, t)** em `received_at` dos recibos `completed`, com atual somada virtualmente uma vez. Baselines usam somente observações anteriores qualificadas, e nunca `processing/failed`. Os valores abaixo são hipóteses configuráveis da v0.4.

Feature / sinais	Escopo, relógio e janela	Status qualificadores e baseline	Mínimo e indisponibilidade
P04 quantidade 5m; P05 montante 1h	Documento pagador; servidor; [t−5min,t), [t−1h,t) + atual	completed: approved, 2FA ou rejected; IDs distintos	Sem histórico = contagem anterior zero conhecida se consulta íntegra; fonte indisponível → unavailable
P07 titulares novos 10m	Pagador + titulares destinatários distintos nas tentativas da janela; servidor [t−10min,t) + atual	É novo se, **antes do início da janela**, não havia relação pagador→titular qualificada por aprovação do motor; congelar esse conjunto no início da janela. Cada titular conta uma vez, mesmo se tentado várias vezes	Exige consulta íntegra da baseline e histórico suficiente do pagador (≥1 aprovação anterior); caso contrário unavailable
P06 mediana	Pagador; aprovações recebidas em [t−90d,t−24h), excluindo as últimas 24h e atual	Somente completed/approved do motor; proxy não liquidado; excluir 2FA/rejected	≥10 aprovações em ≥7 dias; se insuficiente, unavailable; mediana positiva
P09 IP fora do baseline	Pagador/IP; aprovações	Somente completed/approved como proxy; observações apenas tentadas não familiarizam	≥3 aprovações em ≥2 dias com IP válido; se

Feature / sinais	Escopo, relógio e janela	Status qualificadores e baseline	Mínimo e indisponibilidade
	[t−90d,t−24h), excluindo 24h recentes e atual	IP	insuficiente/unavailable, P09 indisponível; IP isolado fraco
REL01 / REL02 relação	Pagador→titular, não conta exata; [t−90d,t−24h) para baseline; avaliação atual excluída	Somente completed/approved do motor. REL02 exige ≥3 aprovações no par distribuídas em ≥7 dias **e nenhum sinal adverso P03/P06/P09/P10, P04/P07, R02/R03, ou restrição ativa nas últimas 24h**; se anomalia conhecida REL02 não aciona. Não confundir ausência de observação com cobertura ausente	REL01 requer ≥1 aprovação anterior do pagador; REL02 requer critérios completos; consulta incompleta/anomalia não avaliável → unavailable (sem redutor); critérios presentes mas não cumpridos → not_triggered
R02 / R03 por titular; R04 por conta exata	R02 [t−10min,t), R03/R04 [t−1h,t) + atual; clock servidor, titulares/contas separados	Todos os completed em qualquer decisão; mesmo pagador distinto conta uma vez em R03/R04	História vazia com consulta íntegra → contagem conhecida; indisponibilidade → unavailable. Corrida entre pagadores é aproximada
L02 soma diária	Pagador; dia civil `America/Sao_Paulo` de `evaluated_at`, [00h,t) + atual	completed em qualquer decisão. Para **cada tentativa passada**, usar o snapshot `device_registration_status_at_evaluation` persistido naquela tentativa; somar somente unregistered. Atual usa registry snapshot atual. Não recalcular histórico com registry de hoje	Registro atual ou snapshot de tentativas necessário; se fonte/snapshot incompleto, unavailable; soma em todos devices não registrados, não por device
P08 compartilhamento de device	device + pagadores distintos [t−24h,t), clock servidor + atual	completed em qualquer decisão	Sem histórico íntegro, zero anterior; consultas incompletas → unavailable
Geografia G01 opcional	Pagador; distância geodésica mínima entre coordenada válida atual e **múltiplos centros habituais** derivados de aprovações qualificadas [t−90d,t−24h)	completed/approved proxy, nunca tentativa corrente nem últimas 24h; agrupar regiões habituais para não penalizar deslocamentos regulares	≥10 observações válidas em ≥7 dias e ≥2 dias distintos por centro; localização atual ausente/inválida ou cobertura insuficiente → unavailable; limiar exploratório >300 km do centro habitual mais próximo → +6 pagador em família comportamento; isolado jamais rejeita ou força 2FA

Qualidade de dados: datas futuras/antigas fora da tolerância devem seguir erro contratual documentado; coordenadas opcionais inválidas não devem gerar distância confiável. Não executar impossible travel nem geolocalização por IP. Não escrever coordenadas precisas em logs ordinários.

6. Pontuação e suficiência das evidências

A soma heurística por eixo é limitada a 0–100; não é probabilidade de fraude. Guardar pontos brutos, teto e contribuição efetiva de cada família para reproduzir exatamente o score. Uma ocorrência externa

identificada pontua uma única vez, ainda que seja citada na explicação da política.

Eixo / família	Sinais	Teto inicial
Pagador — limite contextual	L01, L02	15
Pagador — conta	P01	10
Pagador — velocidade e montante	P04, P05	25
Pagador — comportamento	P03, P06, P07, P08, P09, P10	45
Destinatário — rede	R01, R02, R03, R04	35
Destinatário — relação	REL01 / REL02 / REL03	+8 / redutores até −10
Destinatário — inteligência externa opcional	Ocorrências únicas da fixture, deduplicadas por ID	Peso/teto próprios, definidos antes da ativação e versionados; nunca reaplicar pela política

Suficiência geral do histórico, calculada separadamente por pagador e destinatário e usando observações anteriores:

Observações anteriores	Extensão temporal	Categoria
0	Qualquer	`unavailable`
1–5	Qualquer	`low`
6–29	Um dia	`low`
6–29	Mais de um dia	`medium`
≥30	Um dia	`low`
≥30	Mais de um dia, menos de sete dias	`medium`
≥30	Sete dias ou mais	`high`

A categoria geral não substitui os mínimos específicos de P06/P09/REL02. Disponibilidade do registro bancário e da inteligência externa é independente dessa cobertura: fonte `unavailable` não é sinal negativo nem positivo. Cold start não recebe penalidade artificial.

Política fechada do adaptador simulado de inteligência

Adaptador interno por documento normalizado (pagador ou titular destinatário conforme ocorrência), sem microserviço. Os dados são **fictícios**, independentes de status `approved/rejected/2FA` do próprio motor. Capturar `occurrence_id`, `subject_scope`, `kind`, `severity`, `reported_at`, `expires_at`, `source`, `fixture_version` e estado da consulta. Só usar ocorrência se `reported_at <= evaluated_at < expires_at` (prazo obrigatório nas fixtures); se expirada, não contribui. Deduplicar por `source + occurrence_id` antes de mapear, inclusive em respostas repetidas.

Resultado e significado	Sinal e eixo	Pontos propostos / efeito	Decisão esperada
`clear`: consulta íntegra, zero achados adversos conhecidos	Nenhum sinal positivo	0; não reduzir risco	Restante da política; não selo seguro
`unresolved_report`: denúncia ainda não verificada	EXT01, eixo correspondente ao documento consultado; destinatário por padrão	+8 por ocorrência única; teto externo 25	Apoio ao score, nunca rejected isoladamente
`fraud_related_evidence`: indicador adverso específico ainda não confirmado independentemente	EXT02, mesmo eixo do sujeito consultado	+20 por ocorrência única; teto externo 25	2FA apenas se score combinado atingir limiar, sem rejeição automática
`confirmed_in_mock`: confirmação declarada somente na fixture fictícia	EXT03, eixo do sujeito	+25, teto externo 25	Não gera restrição automaticamente; decisão pela política. Uma restrição

Resultado e significado	Sinal e eixo	Pontos propostos / efeito	Decisão esperada
			semeada e separada pode rejeitar
`missing_coverage`: documento não coberto pela fonte	EXT indisponível	0 observável, não significa clear	Continuar com demais regras, registrar qualidade de dado
`provider_failure` / timeout	EXT indisponível	Sem contribuição presumida, não é clear	Continuar com regras disponíveis; erro/timeout auditado

Sinais EXT usam **família própria** com teto +25 por eixo afetado; não reaplicar pontos na família de rede ou no override. O status geral `suspicious` do provider deve vir acompanhado das ocorrências tipadas acima; `suspicious` sem tipo/evidência identificável não vira pontos ou restrição. Se mesma evidência referencia restrição semeada, a restrição pode decidir primeiro pela sua autoridade simulada, mas não é transformada automaticamente a partir do relatório. Versão/prazo/disponibilidade ficam no EvaluationContext e no snapshot persistido.

G01 geografia opcional: +6 na família de comportamento (teto 45) se passar critérios da tabela da §5; isolado não rejeita nem força 2FA. Adicionar G01 à família de comportamento de P03/P06/P07/P08/P09/P10. Limiar/distância, clustering e cobertura são hipóteses versionadas.

7. Política de decisão v0.4 — tabela ordenada

A primeira condição aplicável determina a resposta. Restrições simuladas são verificadas no contexto imutável antes de indisponibilidade de device. Não derivar restrição de `suspicious` genérico.

Prioridade	Código	Condição	Resultado	Fundamento
0	Contrato / ciclo de recibo	Payload inválido, ID colidente, recibo sem análise ou falha de processamento	400 / 409 / resposta de processamento documentada / erro sem veredito	Não é uma classificação de fraude
1	D-RESTRICT-SIM	Ao menos uma restrição **ativa e aplicável**, semeada para pagador, titular destinatário ou conta destinatária exata	`rejected`	Restrição simulada com razão, referência de evidência, origem, início, expiração/revogação; persistir IDs e snapshot. Independente de score.
2	D-DATA-UNAVAILABLE	Fonte obrigatória de registro do dispositivo indisponível	`two_factor_required`	Fallback explícito, sem inventar score ou registro
3	D-ATO-1	P03 e P06 disparados	`two_factor_required`	Dispositivo não registrado com montante individual fora do padrão
4	D-ATO-2	P03 e P09 disparados	`two_factor_required`	Dispositivo não registrado com IP fora do baseline qualificado
5	D-PAY	`payer_risk >= 40`	`two_factor_required`	Risco acumulado do pagador
6	D-RCP	`recipient_risk >= 40`	`two_factor_required`	Única intervenção intermediária no contrato, insuficiente por si só para golpes induzidos
7	D-OK	Nenhuma anterior, contexto íntegro	`approved`	Não punir desconhecimento isolado

`D-REJ` antigo por R01+R02+R03 permanece removido. Restrição simulado-semeada não é prova de fraude real nem consequência automática de reputação suspeita. Verificar vigência pelo `evaluated_at`: `effective_at <= t` e (`expires_at` nulo ou `t < expires_at`) e (`revoked_at` nulo ou `t < revoked_at`). A ausência de cobertura de restrições precisa ser distinguida de lista completa sem restrições; se a fonte obrigatória não puder ser consultada, não assumir inexistência da restrição, retornar erro de serviço **sem veredito** e registrar falha. Falha do provedor opcional de inteligência vira `unavailable`, sem `clear`. Ocorrência de inteligência externa mencionada pela política não soma pontos novamente.

8. Dados, ciclo do recibo, concorrência e fontes

Recibo separado da avaliação: `pix_receipt` com `external_id` único, hash do payload canônico, `received_at`, estado `processing/completed/failed`, `owner_token`/lease e timestamps. Persistir recibo antes da avaliação em transação curta independente. `pix_transaction` e `pix_transaction_rule_result` contêm análise imutável, evidências, versão e snapshot; `completed` apenas quando análise e resposta foram gravadas atomicamente. Registro `failed` guarda erro sanitizado, tentativa de execução e instante, não resposta fictícia.

Situação	Comportamento do mesmo ID e payload	Contagem
Recibo `processing` e lease vigente	Não iniciar segundo avaliador; devolver erro de processamento temporário documentado (ex.: HTTP 409 com código `PIX_PROCESSING` e `Retry-After`), sem campos de sucesso `key/status/metadata`	Nenhuma duplicação
Recibo `completed`	200 com a resposta previamente gravada, exatamente igual	Nenhuma duplicação
Recibo `failed`	Mesmo conteúdo pode reivindicar nova tentativa de avaliação por transição atômica/lease; nunca criar segundo recibo; se falha for terminal, erro documentado sem veredito	Mesmo ID conta no máximo uma vez, se chegar a avaliação concluída
Crash com `processing` abandonado	Após expirar lease, recuperar em processo/requisição seguinte mediante compare-and-swap, com `owner_token` para impedir gravação tardia do dono antigo	Não duplicar observação nem sinais
Mesmo ID, payload divergente	409 `PixTransactionIdConflict`, independentemente do estado	Nenhuma duplicação
GET com recibo sem análise completa	Retornar resposta de erro/estado de processamento documentada (ex.: 409 `PIX_PROCESSING` ou 503 `PIX_EVALUATION_FAILED`), nunca forjar formato de sucesso	Somente consulta

Elegibilidade para velocidade: somente recibos `completed` com análise persistida contam como tentativas avaliadas, em qualquer status de antifraude; recibos `processing`/`failed` não contam. Reprocessar mesmo ID não acrescenta tentativa, independentemente de quantas execuções ocorreram. Esta é uma limitação explícita: tentativas que nunca completaram avaliação são auditadas como recibos, mas não participam dos contadores de risco. A avaliação atual entra uma vez virtualmente no cálculo antes de seu commit.

Fontes internas: `payer_device_registration` semeada por par pagador-device, `registered_at`, `revoked_at` e provenance; POST Pix nunca modifica registro. `security_information_provider` é adaptador interno por documento com fixtures de informação externa fictícia. `simulated_restriction` separado do provedor de reputação genérica: `restriction_id`, `scope` (`payer`, `recipient_holder`, `recipient_account`), `identity_key`, `reason`, `evidence_ref`, `provenance=demo_seed`, `effective_at`, `expires_at`, `revoked_at`; semeadura controlada fora da API. Não inferir restrição de relatórios comuns ou de respostas `suspicious`.

Contexto imutável de avaliação: montar **uma vez**, após claim do recibo e locks relevantes, o `evaluation_clock`, hashes/chaves normalizadas, feature values + elegibilidade/contagens, snapshot do cadastro de device e seu estado, restrições consultadas, ocorrências de reputação deduplicadas, disponibilidade/freshness das fontes, e versões da política, features e fixtures. Regras, agregador e política recebem somente este contexto — sem nova consulta a banco/provedor no meio do cálculo.

Persistir o contexto ou as evidências suficientes para replay offline; GET sempre devolve a decisão original mesmo após mudar fixture.

Concorrência e falhas: lock transacional por pagador antes do histórico. Entre pagadores para mesmo titular, os agregados de rede são aproximados em READ COMMITTED; testar corrida cruzada e não usar limiares como rejeição incondicional. Restrições aplicáveis são lidas do snapshot consistente e avaliadas antes do fallback de device. Índices orientados a consultas reais, validados por EXPLAIN ANALYZE. Timeout sem veredito não autoriza transferência. Medir latência, falha de avaliação, recuperação e indisponibilidade de fontes. Logs com request ID, sem documentos/coordenas geográficas precisas.

9. Cenários de aceitação (18) e regressões v0.4

Fixtures da fonte bancária e de inteligência devem ser preparadas **separadamente** dos POSTs de Pix. O histórico de tentativas é reproduzido via HTTP; nunca inventar confirmação de 2FA. Cada cenário confere `status`, `decision_rule`, sinais (inclusive `unavailable`), evidências, pontos brutos e limitados, versão e GET persistido. Os valores devem ser recalculados com todos os sinais realmente acionados, e não somente o sinal focal.

#	Cenário	Preparação / estímulo	Resultado esperado v0.4	Teste sugerido
01	Primeira observação normal	Contas maduras; R$150; dispositivo registrado; sem histórico	approved; histórico unavailable	test_primeira_observacao_normal_aprova
02	Primeiro Pix alto à noite	R$5000 às 03h; dispositivo registrado	L01; decisão antifraude isolada pode aprovar, sujeita a limites upstream	test_primeiro_pix_noturno
03	Conta nova isolada	Conta destino há 2 dias; sem outra anomalia	R01; approved	test_destino_novo_isolado
04	Mesmo titular	CPF/CNPJ normalizado igual; valor usual	REL03 redutor, approved na fixture	test_autotransferencia
05	Relação recorrente	≥3 aprovações anteriores do motor ao titular ao longo ≥7 dias	REL02 reduz; tentativas rejeitadas/desafiadas não qualificam	test_relacao_recorrente_aprovada
06	Device sem registro e valor anômalo	Registry completo: par não registrado; P06 qualificado	D-ATO-1; 2FA	test_nao_registrado_valor_atipico
07	Device não registrado isolado	Valor R$100, baseline IP habitual, demais sinais normais	P03 isolado; pode aprovar, sem cadastrar device	test_device_nao_registrado_isolado
08	Quinta tentativa em 5 min	4 tentativas anteriores e atual, IDs distintos	P04 dispara; verificar score e decisão completa	test_quinta_tentativa

#	Cenário	Preparação / estímulo	Resultado esperado v0.4	Teste sugerido
09	Fracionamento	P04, P05 e P07 acionados, teto aplicado	D-PAY se payer ≥40; 2FA	test_fracionamento
10	Payer frequente habitual	Histórico estável, fixture não aciona condições extraordinárias	approved se nenhum limiar combinado disparar	test_pagador_habitual
11	Titular maduro popular	≥4 pagadores/h, sem conta nova concentrada	R03 isolado; não rejected	test_destino_maduro_popular
12	Conta nova concentrando	R01 e contagem da mesma conta; holder também pode ter rajada	D-RCP se risco ≥40; nunca D-REJ	test_conta_nova_concentrando
13	Pagador típico para destino suspeito	Pagador habitual; destino com indícios do caso 12	Sem D-REJ; 2FA conforme score, com ressalva sobre golpe	test_pagador_tipico_destino_risco
14	Geolocalização ausente	Campo opcional não fornecido; resto habitual	Não soma nem reduz risco; approved na fixture	test_geo_ausente
15	Reenvio e concorrência pagador	Mesmo ID e conteúdo 2×; divergente; simultâneos	201/200 mesmo snapshot; 409 divergente; contagem uma vez	test_idempotencia_e_lock_pagador
16	Novo IP e device registrado	Baseline IP suficiente; IP atual novo	P09 isolado não força 2FA	test_ip_novo_isolado
17	Device não registrado e IP fora baseline	Mesmo par já recebeu 2FA não resolvido com ID distinto	D-ATO-2 permanece; tentativa não gera confiança	test_2fa_nao_familiariza_device
18	Não registrado e valor >5×	Mediana qualificada e registro ausente em fixture completa	D-ATO-1; 2FA	test_device_nao_registrado_valor_5x

Regressões específicas

ID	Teste e condição obrigatória	Propriedade que demonstra
A	Repetir o mesmo device/IP com novo ID depois de 2FA pendente	Observação não promove registro nem normaliza IP de baseline
B	Device registrado mas nunca observado; observado sem registro; revogado; registry indisponível	P03 baseia-se no cadastro; fonte indisponível aciona D-DATA-UNAVAILABLE sem pontos falsos

ID	Teste e condição obrigatória	Propriedade que demonstra
C	Repetir tentativas rejected/2FA no mesmo par	Não alimentam REL02 nem mediana P06
D	Titular recebe em conta antiga; primeira transferência à nova conta dele	R01/R04 por conta; R02/R03 por titular; sem inventar concentração na nova conta
E	Comércio novo com cinco entradas e quatro pagadores distintos	Não há rejeição incondicional D-REJ
F	Cinco pagadores simultâneos ao mesmo titular	Reconhecer detecção aproximada e concorrência cruzada; não prometer quinto bloqueado
G	Fixture externa clear, suspicious, confirmed_in_mock, unavailable, timeout, ocorrência duplicada	Ausência não é segurança; ocorrência identificada soma uma vez; persistir fonte/versão
H	CPF/CNPJ com zeros e letras se schema permitir; data futura/antiga, fuso e virada de dia	Chaves não corrompidas e relógio do servidor preservado
I	L02 com soma diária distribuída em múltiplos devices não registrados	Agregado por pagador, não uma franquia por device
J	Falha do motor após recibo confirmado; timeout; mudança posterior de política e fixture	Recibo failed persiste, nenhum veredito falso, GET da análise concluída imutável
K	Scores e suficiência em todos os limites e duração dos históricos	Soma dos pontos após teto e categorias completas/reproduzíveis

Fronteiras: P01 6/7 dias; L01 19:59/20:00 e 05:59/06:00, R$1000 exato/acima; L02 R$200 exato/acima e R$1000 diário exato/acima em múltiplos devices; P04 4/5; P05 R$8000 exato/acima; P06 razão 5 exata/acima; R02 4/5, R03 3/4 titulares pagadores, R04 3/4 pagadores na conta exata.

Casos adicionais para esta consolidação

ID	Fixture / ação	Resultado exigido
R1	Restrição ativa no pagador, titular ou conta exata; device registry simultaneamente indisponível	`D-RESTRICT-SIM` prevalece sobre `D-DATA-UNAVAILABLE`; rejected só pela restrição simulada, com motivo/evidence_ref/proveniência
R2	Restrição ainda futura, expirada ou revogada; reputação `suspicious` sem restrição	Não rejected automaticamente; verificar limites de vigência pelo relógio controlado
R3	Fonte obrigatória de restrições falha / cobertura desconhecida	Erro sem veredito; não supor inexistência de restrição nem converter em approved
C1	Dois POSTs idênticos durante processing; GET enquanto ainda processing	Um avaliador/recibo/attempt; resposta de processamento documentada, sem resposta Pix falsa
C2	Retry após failed; crash no processing antes/depois da gravação de avaliação; lease expirado e gravação tardia do dono antigo	Claim exclusivo, fencing por owner_token; recuperar ou devolver resposta já concluída; ID contado no máximo uma vez
C3	Recibo failed/processing, outro receipt completed, tentativa avaliada rejected	Velocity inclui apenas completed, uma vez por ID, independentemente do status antifraude
F1	Relógio de testes avança por limites [t−janela,t), corte de 24h, sete dias e meia-noite SP	Features P04/P05/P06/P07/P09/REL02/L02 respeitam cada fronteira e o mesmo clock de avaliação
F2	Registro de device muda entre duas avaliações; histórico L02 inclui duas tentativas sob estados antigos diferentes	Cada decisão usa snapshot próprio; L02 usa registro gravado de cada tentativa, não situação atual recalculada
F3	REL02 com anomalia nas últimas 24h e P07 repetindo titular novo dentro da janela	Redutor ausente e titular conta uma única vez; baseline de novidade congelada antes da janela

ID	Fixture / ação	Resultado exigido
E1	Zero achado, denúncia não resolvida, evidência adversa, confirmação fictícia, missing coverage, timeout, dados expirados e ocorrência duplicada	EXT correto, prazo e pontos/teto próprios; mesma ocorrência entra uma vez; nenhum tipo vira restrição automaticamente
G1	Local habitual múltiplo e localização atual distante; geolocation ausente; pontos inválidos; poucos registros; tentativa atual muito distante	G01 fraco só com baseline qualificado; unavailable sem cobertura; excluir tentativa atual e evitar false positive em locais habituais múltiplos
V1	Salvar EvaluationContext, modificar fixtures/cadastro/pesos e consultar GET	Resposta histórica imutável, evidência e política antigas reproduzíveis
V2	Comando offline opcional aplica política ativa e candidata ao **mesmo conjunto de contextos salvos**, sem POST/GET de produção	Relatório de diferenças de score/status/regra, sem alterar histórico, decisão ou versão de avaliações já persistidas

Relógio de teste: `Clock` injetável apenas na composição da aplicação em ambiente de teste, fixável/avançável pelo harness de testes HTTP; nunca parâmetro público aceito por clientes de produção. Testar falta de veredito sem romper o formato dos três campos de respostas **bem-sucedidas**.

10. Limites conhecidos

O que este motor não pega, e por quê (útil na apresentação):

- **Fora do payload:** comprovante falso (#3), Pix agendado cancelado (#5), aumento de limite (#15), abuso do MED (#19) e Pix Automático/parcelado/biometria (#20). Nada disso aparece no que recebemos.
- **Só por proxy:** "Pix errado" com devolução para outra chave (#2) e Pix por aproximação (#16) dependeriam de dados que não temos (entrada anterior e tipo de pagamento).
- **Sinais invisíveis:** nome do recebedor, chave Pix, ligação ativa, app de acesso remoto e QR trocado. Pegamos só o efeito: destino novo, device novo, valor atípico.
- **Engenharia social:** em falsa central e falso parente (#1, #6), quem autoriza é a própria vítima. O 2FA cria uma pausa, não uma proteção. Um produto real precisaria de alerta contextual.
- **Visão local:** R02 e R03 só enxergam o tráfego desta API.

11. Questões abertas e ordem de implementação

1. Conferir no Base Service o schema concreto de CPF/CNPJ, persistência e os contratos de erro antes de adaptar o banco. Não alterar contratos silenciosamente.
2. Implementar receipt durável, identidade, tempo, idempotência e o provedor de cadastro do dispositivo semeado independentemente; demonstrar primeiro a regressão da tentativa desafiada repetida.
3. Implementar features por titular e conta separadamente, sinais e agregador, incluindo `unavailable` da fonte de cadastro e da inteligência externa; preservar fatos externos deduplicados.
4. Aplicar a política única da seção 7 e todos os cenários da seção 9. Registrar status e razões de cada avaliação. Validar score, teto, regra decisora e GET.
5. Calibrar apenas com cenários simulados: taxas de aprovação/2FA, custo de intervenção, latência e falsos positivos ilustrativos. Sem rótulos reais, não afirmar precisão, recall ou probabilidade de fraude.
6. Próxima iteração: gastos cumulativos relativos ao baseline do pagador e mudança de atividade da conta/titular destinatário, inclusive contas maduras. Manter baseline anterior congelado e piso absoluto para não criar alarmes por valores mínimos. ML apenas com feedback rotulado posterior.

12. Da RFC ao README

O README do desafio deve explicar a arquitetura, a configuração, os dados fictícios, as regras e os testes de forma reproduzível.

Seção do README	Fonte na RFC v0.4	Conteúdo esperado
Contexto e escopo	§1, §3 e §10	O que o motor observa; limites do payload; cadastro e informação externa simulados
Contrato e execução	§2, §8	POST/GET, Docker/ambiente, banco, auth, erros, receipt, seeding
Arquitetura	§4	Diagrama e separação entre histórico, features, regras, scorer e policy
Regras / lógica / parâmetros / justificativa	§5–6	Catálogo, valores em centavos, história exigida, famílias e tetos
Da pontuação à decisão	§7	Tabela ordenada, D-DATA-UNAVAILABLE, D-REJ desativada, sem enforcement regulatório
Testes	§9	Fixtures independentes, 18 cenários, regressões, fronteiras e comandos pytest
Resultados e limitações	§10–11	Distribuição de decisões/latência se medida; sem alegar precisão sem rótulos reais

13. Alternativas descartadas e custo da decisão

Alternativa	Por que não está na v0.4	Quando reconsiderar
Rejeitar com recipient_risk ≥70	Inalcançável com os tetos da versão original	Nova calibração e evidência confiável
Rejeição D-REJ por R01 + R02 + R03	Confunde conta com titular; sinais correlacionados geram falsos positivos em comerciantes novos	Dados adversos adicionais, escopo consistente e testes de falso positivo
Dispositivo previamente observado = cadastrado	Tentativa com 2FA não resolvido criaria falsa familiaridade	Não reutilizar: status de registro deve vir de fonte bancária independente
Considerar tentativas rejeitadas/desafiadas como pagamento recorrente	Estabeleceria REL02 e mediana P06 com tentativas sem conclusão	Somente após callback confiável de autenticação e liquidação; aprovações do motor continuam proxy limitado
Limites noturno/device como enforcement na API	Faltam parâmetros e dados bancários; L01/L02 são heurísticas	Integração contratual com controles do banco
Usar só conta exata ou só documento do titular	Fragmenta redes ou mistura indevidamente atributos de contas diferentes	Manter ambas as chaves e nomear granularidade por sinal
Bloqueio exato por destinatário com apenas lock no pagador	Requisições de outros pagadores podem observar snapshots concorrentes	Se houver rejeição baseada nesses contadores, introduzir sincronização do titular/conta com ordem de locks
Modelo treinado sem rótulos	Não há verdade de fraude nem validação de precisão real	Feedback pós-transação e avaliação offline
Fonte externa obrigatoriamente via serviço HTTP	Deployment desnecessariamente complexo para fixture de demonstração	Se houver fornecedor externo real ou exigência de desacoplamento operacional

14. Critérios de aceite v0.4 e changelog

- Existe uma única política executável (§7): D-REJ por contadores segue desativada; somente restrição simulada ativa e aplicável pode gerar rejected nesta versão, antes do fallback de dispositivo. Decisões completas são persistidas e explicáveis.
- Registro pagador–device semeado separado de observação; repetição da tentativa desafiada não produz familiaridade falsa. Fonte indisponível gera regra `unavailable` e fallback explícito sem imputar pontuação falsa.
- Titular e conta de destino não se confundem. R01/R04 usam conta exata, R02/R03 usam titular com contagens da conta expostas separadamente.
- Histórico-baseline não aceita rejeições ou desafios como evidência tranquilizadora. Categorias gerais de suficiência cobrem toda combinação de quantidade/duração, e mínimos específicos prevalecem.
- Informação de segurança vem de adaptador com fixtures por documento; indisponibilidade registrada e mesma ocorrência nunca pontuada duas vezes.
- Recibo durável permanece se avaliação falhar. Concorrência de pagadores distintos, atraso de fonte, timeout e resultado não disponível têm testes explícitos.
- Casos v0.4 e regressões §9 substituem expectativas antigas; testes conferem sinais, valores observados, contribuições e decisão, não somente status.

Changelog v0.3 → v0.4

- P03/L02/P10/D-ATO redefinidos em torno do cadastro bancário simulado de dispositivos; P09 usa IP fora de baseline qualificado, distinto de IP apenas observado.
- Fallback `D-DATA-UNAVAILABLE` e persistência de proveniência da fonte; sem aprovação por ausência de dados.
- D-REJ removida; R04 usa concentração na conta exata, preservando R02/R03 por titular. Cenários 12/13 e exemplo legítimo de comerciante atualizados.
- Recibo/falha durável separado da avaliação; regras de concorrência e sem veredito esclarecidas.
- Suficiência com todos os casos cobertos; novos testes da fonte de inteligência simulada, falhas e deduplicação da evidência.
- L01/L02 explicitamente heurísticas; documentos e tempo normalizados segundo schema verificado.

Histórico das decisões anteriores

v0.3 distinguiu titular e conta destinatária; v0.2 estruturou contrato, score e tabela ordenada. As definições da v0.4 acima substituem suas condições conflitantes.